

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (Syft + Gripe, NVD-confirmed) · Generated 2026-07-09 · Source: `pom.xml` @ `61ed8c3`

Methodology note. OWASP Dependency-Check's Maven plugin was attempted first, but this environment has no warm NVD database volume and no `NVD_API_KEY` ; a cold sync reported **346,530 records** to download, which is infeasible inside a single scan session. Per the risk-scoring skill's "NVD fallback" guidance, the scan instead used **Syft (SBOM) + Gripe** (GHSA/NVD-backed vulnerability DB, ~44s scan) and confirmed the headline CVEs directly against the live NVD REST API (`services.nvd.nist.gov` , reachable and fast in this environment). Every CVSS score below is either scanner-confirmed against NVD directly, or sourced from Gripe's NVD-derived metric where a direct NVD lookup wasn't run for long-tail CVEs.

Summary

Metric	Count
Total CVEs found	68
CRITICAL dependencies	3
HIGH dependencies	1
MEDIUM dependencies	3
LOW dependencies	0
Total dependencies scanned	24 (23 resolved + 1 unresolvable typosquat)
Outdated dependencies	8
License violations	1 (+1 flagged for review)
Supply-chain alerts	2

Known-vulnerable dependencies

Dependency	Version	Top CVE	CVSS	Severity	Fix version
org.apache.logging.log4j:log4j-core	2.14.1	CVE-2021-44228 (Log4Shell)	10.0	CRITICAL	2.15.0 (2.26.1 recommended)
com.fasterxml.jackson.core:jackson-databind	2.9.8	CVE-2019-14379 / CVE-2020-8840 (+43 more)	9.8	CRITICAL	2.18.8 (2.22.1 latest)
mysql:mysql-connector-java	8.0.30	CVE-2023-22102	8.3	HIGH	8.0.33
com.google.guava:guava	24.1.1-jre	CVE-2023-2976	5.5	MEDIUM	32.0.0-android (33.6.0-jre latest)
org.apache.commons:commons-lang3	3.4	CVE-2025-48924	5.3	MEDIUM	3.18.0
commons-io:commons-io	2.4	CVE-2021-29425	4.8	MEDIUM	2.7 (2.14.0 for full coverage)

NVD confirmation note. Gripe/GHSA rated `guava` CVE-2023-2976 as 7.1 (HIGH); a direct NVD lookup returned the authoritative

5.5 (MEDIUM). The NVD score is used throughout this report and the risk scoring downstream.

All CVEs (top dependencies, highest CVSS first)

CVE	Dependency	CVSS	Severity
CVE-2021-44228	log4j-core	10.0	CRITICAL
CVE-2019-14379	jackson-databind	9.8	CRITICAL
CVE-2019-14540	jackson-databind	9.8	CRITICAL
CVE-2020-8840	jackson-databind	9.8	CRITICAL
CVE-2019-16335 / -16942 / -16943 / -17267 / -17531 / -19527 / -20330 / -9546 / -9547 / -9548 (10 more)	jackson-databind	9.8	CRITICAL
CVE-2021-45046	log4j-core	9.0	CRITICAL
CVE-2023-22102	mysql-connector-java	8.3	HIGH
CVE-2020-10672 / -10673 / -10968 / -10969 / -11111 / -11112 / -11113	jackson-databind	8.8	HIGH
CVE-2020-10650 / -11619 / -11620 / -14060 / -14061 / -14062 / -14195 / -20190 / -24616 / -24750 / -35490...-36189 (18 records)	jackson-databind	8.1	HIGH
CVE-2026-34480	log4j-core	7.5	HIGH
CVE-2019-12086 / -14439 / -20649 / -36518, CVE-2022-42003 / -42004	jackson-databind	7.5	HIGH
CVE-2023-2976	guava	5.5	MEDIUM
CVE-2021-44832	log4j-core	6.6	MEDIUM
CVE-2021-45105 / CVE-2026-34477	log4j-core	5.9	MEDIUM
CVE-2019-12384 / -12814	jackson-databind	5.9	MEDIUM
CVE-2025-48924	commons-lang3	5.3	MEDIUM
CVE-2026-54514 / CVE-2026-54515	jackson-databind	5.3	MEDIUM
CVE-2021-29425	commons-io	4.8	MEDIUM
CVE-2025-68161	log4j-core	4.8	MEDIUM
CVE-2024-47554	commons-io	4.3	MEDIUM
CVE-2020-8908	guava	3.3	LOW

*jackson-databind 2.9.8 alone carries **45** distinct known CVEs (deserialization gadget-chain family accumulated 2019–2026); only the highest-value ones are itemized above — see `depscan-report.json` → `findings[].cves` for the full machine-readable list.*

Outdated dependencies (8)

Dependency	Current	Latest (same major)	Type
com.google.guava:guava	24.1.1-jre	33.6.0-jre	major
org.apache.logging.log4j:log4j-core	2.14.1	2.26.1	minor
org.apache.logging.log4j:log4j-api	2.14.1	2.26.1	minor
com.fasterxml.jackson.core:jackson-databind	2.9.8	2.22.1	minor
org.apache.commons:commons-lang3	3.4	3.20.0	minor

commons-io:commons-io	2.4	2.22.0	minor
mysql:mysql-connector-java	8.0.30	8.0.33	patch
org.junit.jupiter:junit-jupiter (test)	5.10.2	5.14.4	minor

License findings

Dependency	License	Status
mysql:mysql-connector-java:8.0.30	GPL-2.0, with FOSS exception	VIOLATION
org.checkerframework:checker-compat-qual:2.0.0 (transitive of guava)	GPL-2.0-classpath-exception / MIT (dual)	REVIEW

Supply-chain alerts

CRITICAL — Typosquatted dependency. `com.fastxml.jackson.core:jackson-databind:2.9.8` impersonates the legitimate `com.fasterxml.jackson.core:jackson-databind` (missing the "er" in "faster"); the coordinate does not exist on Maven Central and fails resolution by design. **Remove immediately.**

HIGH — Untrusted repository. `http://insecure-mirror.example.net/maven2` is a plain-HTTP Maven repository (MITM artifact-injection risk). Remove or replace with HTTPS.